Name: Shivanagouda Patil

Lab: Lab 5 — Static Code Analysis

Assigned repository: https://github.com/SETAPESU26/L5_34_online_exam

Main submission repository:
https://github.com/shivanagouda19/SE_LAB_PES2UG24CS471_SEC_H

Before Fixing

Pylint report –

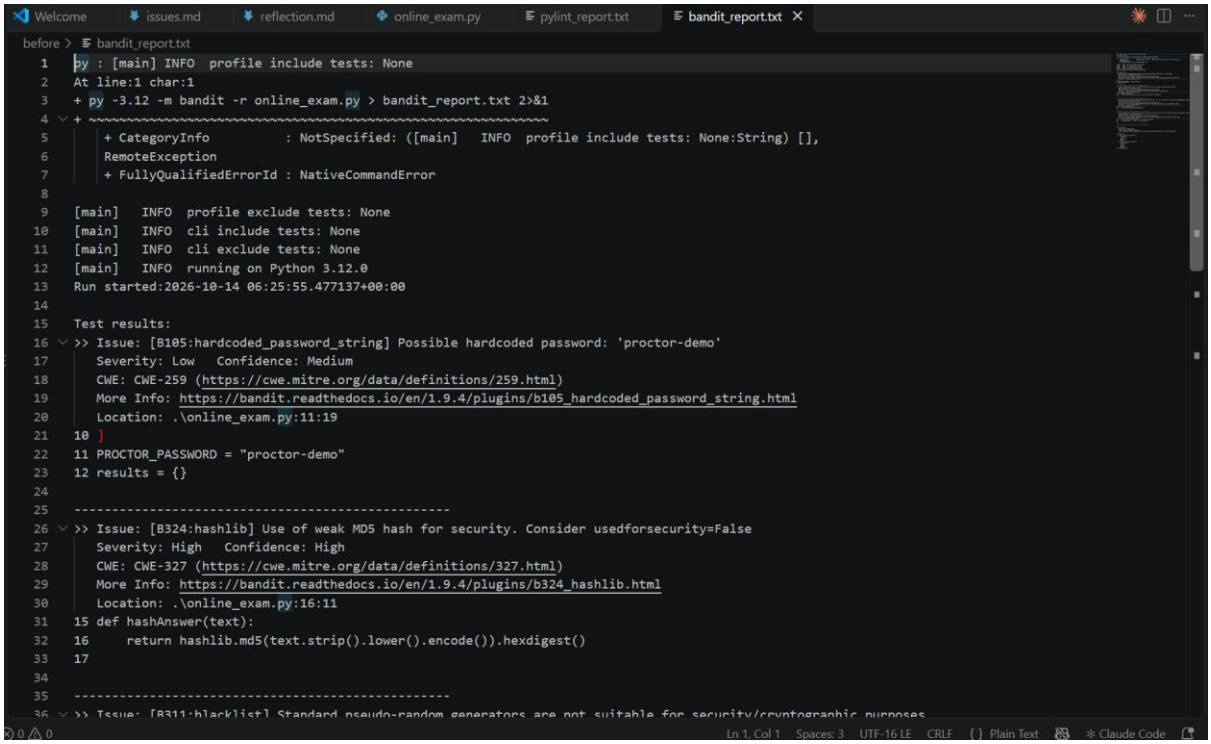
before > pylint_report.txt

```
************* Module online_exam
online_exam.py:1:0: C0114: Missing module docstring (missing-module-docstring)
online_exam.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
online_exam.py:15:0: C0103: Function name "hashAnswer" doesn't conform to snake_case naming style (invalid-name)
online_exam.py:19:0: C0116: Missing function or method docstring (missing-function-docstring)
online_exam.py:19:0: C0103: Function name "pickBonusQuestion" doesn't conform to snake_case naming style (invalid-name)
online_exam.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
online_exam.py:23:0: C0103: Function name "gradeStudent" doesn't conform to snake_case naming style (invalid-name)
online_exam.py:23:17: C0103: Argument name "studentName" doesn't conform to snake_case naming style (invalid-name)
online_exam.py:23:0: W0102: Dangerous default value {} as argument (dangerous-default-value)
online_exam.py:25:4: C0200: Consider using enumerate instead of iterating with range and len (consider-using-enumerate)
online_exam.py:35:0: C0116: Missing function or method docstring (missing-function-docstring)
online_exam.py:35:0: C0103: Function name "getGrade" doesn't conform to snake_case naming style (invalid-name)
online_exam.py:37:4: R1705: Unnecessary "elif" after "return", replace only that "elif" with "if" (no-else-return)
online_exam.py:45:0: C0116: Missing function or method docstring (missing-function-docstring)
online_exam.py:45:0: C0103: Function name "classAverage" doesn't conform to snake_case naming style (invalid-name)
online_exam.py:51:0: C0116: Missing function or method docstring (missing-function-docstring)
online_exam.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
online_exam.py:54:0: C0103: Function name "lockScreen" doesn't conform to snake_case naming style (invalid-name)
online_exam.py:54:15: C0103: Argument name "labPc" doesn't conform to snake_case naming style (invalid-name)
online_exam.py:59:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 5.65/10

```

Bandit report



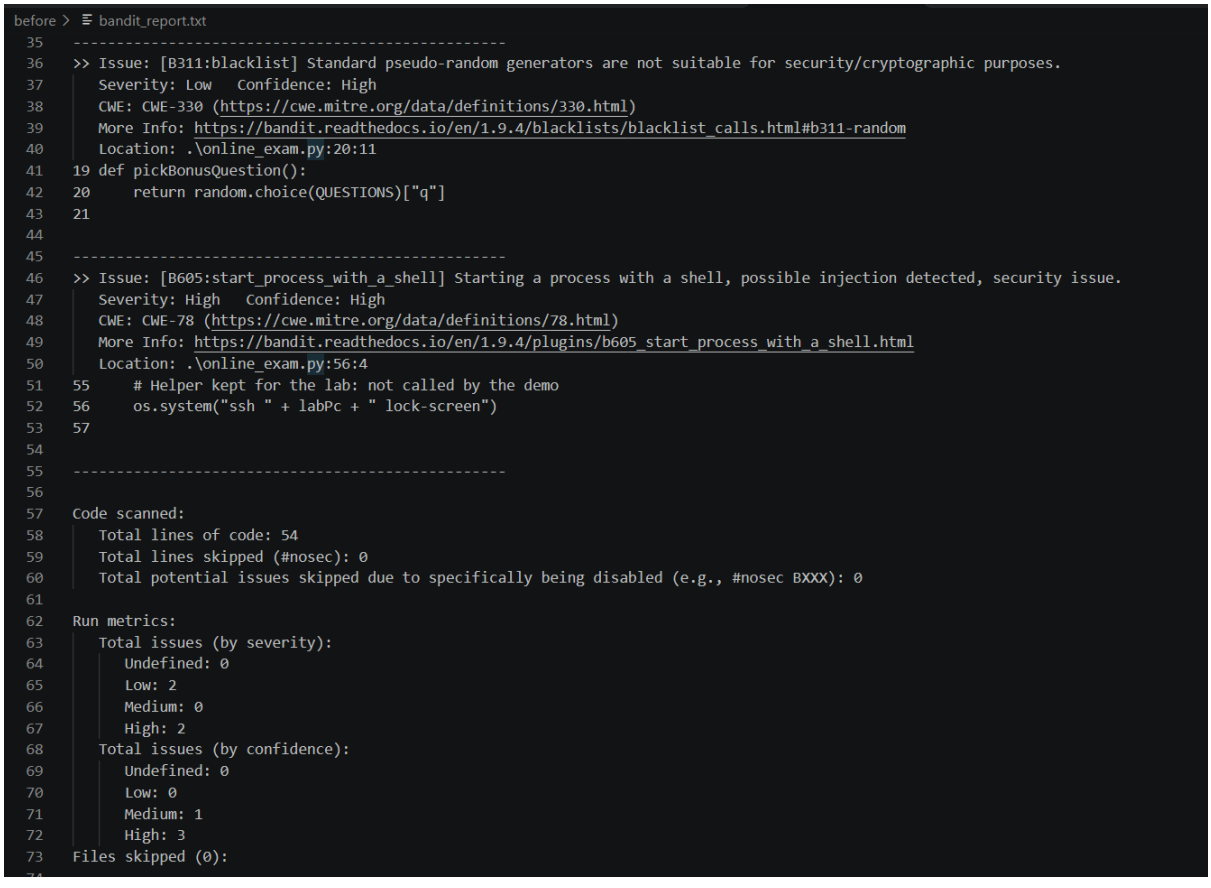
```
Welcome | issues.md | reflection.md | online_exam.py | pylint_report.txt | bandit_report.txt
before > bandit_report.txt
py : [main] INFO  profile include tests: None
At line:1 char:1
+ py -3.12 -m bandit -r online_exam.py > bandit_report.txt 2>&1
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: ([main]   INFO  profile include tests: None:String) [],
    RemoteException
    + FullyQualifiedErrorId : NativeCommandError

[main]   INFO  profile exclude tests: None
[main]   INFO  cli include tests: None
[main]   INFO  cli exclude tests: None
[main]   INFO  running on Python 3.12.0
Run started:2026-10-14 06:25:55.477137+00:00

Test results:
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'proctor-demo'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\online_exam.py:11:19
10 ]
11 PROCTOR_PASSWORD = "proctor-demo"
12 results = {}

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\online_exam.py:16:11
15 def hashAnswer(text):
16     return hashlib.md5(text.strip().lower().encode()).hexdigest()
17

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
```



```
before > bandit_report.txt
--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\online_exam.py:20:11
19 def pickBonusQuestion():
20     return random.choice(QUESTIONS)["q"]
21

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\online_exam.py:56:4
55     # Helper kept for the lab: not called by the demo
56     os.system("ssh " + labPc + " lock-screen")
57

--------------------------------------------------

Code scanned:
   Total lines of code: 54
   Total lines skipped (#nosec): 0
   Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
   Total issues (by severity):
      Undefined: 0
      Low: 2
      Medium: 0
      High: 2
   Total issues (by confidence):
      Undefined: 0
      Low: 0
      Medium: 1
      High: 3
Files skipped (0):
```

Flake8 report

before > flake8_report.txt

```
1  online_exam.py:54:1: E302 expected 2 blank lines, found 1
2  online_exam.py:67:12: E225 missing whitespace around operator
3  online_exam.py:69:31: E261 at least two spaces before inline comment
4  online_exam.py:70:80: E501 line too long (93 > 79 characters)
5
```

After Fixing

Pylint report

after > pylint_report.txt

```
1
2  ------------------------------------------------------------------
3  Your code has been rated at 10.00/10 (previous run: 5.65/10, +4.35)
4
5
```

Flake8 report — empty output (no violations reported)



Bandit report

after > bandit_report.txt

```
py : [main] INFO  profile include tests: None
At line:1 char:1
+ py -3.12 -m bandit -r after\online_exam.py > after\bandit_report.txt  ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: ([main]   INFO  profile include tests: None:String) [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError

[main]   INFO  profile exclude tests: None
[main]   INFO  cli include tests: None
[main]   INFO  cli exclude tests: None
[main]   INFO  running on Python 3.12.0
Run started:2026-10-14 17:52:49.545385+00:00

Test results:
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess
   Location: .\after\online_exam.py:8:0
7  import secrets
8  import subprocess
9

--------------------------------------------------
>> Issue: [B607:start_process_with_partial_path] Starting a process with a partial executable path
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b607_start_process_with_partial_path.html
   Location: .\after\online_exam.py:83:4
82
83      subprocess.run(
84          ["ssh", lab_pc, "lock-screen"],
85          check=True,
86          shell=False,
87      )
```

after > bandit_report.txt

```
88

--------------------------------------------------
>> Issue: [B603:subprocess_without_shell_equals_true] subprocess call - check for execution of untrusted input.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b603_subprocess_without_shell_equals_true.html
   Location: .\after\online_exam.py:86:4
85          check=True,
86          shell=False,
87      )
88

89
90 def main():
91      """Run the online exam demonstration."""

--------------------------------------------------

Code scanned:
   Total lines of code: 90
   Total lines skipped (#nosec): 0
   Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
   Total issues (by severity):
      Undefined: 0
      Low: 3
      Medium: 0
      High: 0
   Total issues (by confidence):
      Undefined: 0
      Low: 0
      Medium: 0
      High: 3
Files skipped (0):
```

Issue Documentation

Issues Identified and Fixed

issues	Type	Original	Description	Approach
Weak MD5 hashing	Security	16	MD5 is not suitable for security-sensitive hashing.	Replaced MD5 with SHA-256 for normalized answer comparison.
Hardcoded proctor password	Security	11	The password was stored directly in the source code.	Read the password from an environment variable using os.getenv().
Unsafe shell command execution	Security	56	os.system() used string concatenation to construct a shell command.	Replaced it with subprocess.run(), shell=False, and computer-name validation.
Mutable default argument	Bug / Code quality	23	penalties={} could share a dictionary between calls.	Changed the default to None and initialized a dictionary inside the function.
Non-standard function names	Code quality	15, 19, 23, 35, 45, 54	Function names did not follow the recommended snake_case convention.	Renamed functions and updated their calls.
Missing docstrings	Code quality	Multiple	Functions and the module lacked documentation.	Added module and function docstrings.
Loop improvement	Code quality	25	The loop used range(len(QUESTIONS)).	Used enumerate() to iterate through questions.
Formatting violations	Style	54, 67, 69, 70	Flake8 reported blank-line, whitespace, inline-comment, and line-length violations.	Corrected spacing and formatting.

Verification

After the fixes, the static analysis tools were run again.

- **Pylint score improved from 5.65/10 to 10.00/10.**
- **Bandit no longer reported the original two high-severity and two low-severity findings. The updated report contained three low-severity subprocess-related findings.**
- **Flake8 produced an empty report, indicating that no style violations were reported.**

Reflection

1. What is static code analysis, and why is it useful?

Static code analysis examines source code without executing the program. It helps identify potential bugs, security vulnerabilities, and coding-style violations early in development. This improves code quality, readability, and maintainability.

2. What is the difference between Pylint, Bandit, and Flake8?

Pylint focuses on code quality, programming practices, and potential logical errors. Bandit identifies common security vulnerabilities and insecure coding patterns. Flake8 checks Python style conventions and common programming errors.

3. What issues did you identify and fix during this lab?

I addressed the use of MD5 hashing, a hardcoded proctor password, shell command execution using os.system(), and a mutable default argument. I also improved function naming, documentation, and code formatting.

4. How did static analysis help improve your program?

Static analysis provided actionable feedback about code quality, security, and formatting. The Pylint score improved from 5.65/10 to 10.00/10, the original high-severity Bandit findings were no longer reported, and Flake8 reported no remaining style violations. Bandit still reported three low-severity findings, which highlighted the importance of reviewing and interpreting warnings rather than assuming every issue has been eliminated.